Broken Authentication

Week 6 Notes | OWASP Top 10 | DG Cyber Security Internship | Diksha Uma Shankar Raul

What it is

Broken Authentication covers weaknesses in how an application confirms who a user is and keeps them logged in. This includes login, password handling, session management and account recovery. When these are weak, attackers can take over other users' accounts. It appears in the OWASP Top 10 under authentication and identification failures.

Common weaknesses

- Weak, default or commonly used passwords (for example admin / password) -

No limit on login attempts, allowing brute-force and credential-stuffing attacks -

Predictable or guessable session IDs

- Session IDs exposed in URLs, or not changed after login (session fixation) -

Sessions that never expire or are not destroyed on logout

- Passwords stored in plain text or with weak hashing

- Weak password reset or recovery questions

- No multi-factor authentication (MFA)

Attack examples

Brute force: trying many passwords against one account.

Credential stuffing: trying username and password pairs leaked from other websites.

Session hijacking: stealing or guessing a valid session ID to act as the logged-in user.

Relation to this project

DVWA includes Brute Force and Weak Session IDs modules for practising these issues. The DVWA login itself uses the default credentials admin / password, which is an example of a default-credential weakness. This is acceptable only because it is a training application.

Impact

Account takeover, access to private data, fraud, and in the case of admin accounts, full control of the application.

Prevention

- Enable **multi-factor authentication**

- Enforce long passwords and block known breached or common passwords -

Add rate limiting, account lockout or CAPTCHA to stop automated guessing -

Hash passwords with a strong algorithm such as bcrypt or Argon2

- Generate long, random session IDs and create a new one after login

- Set session timeouts and fully invalidate the session on logout

- Use Secure, HttpOnly and SameSite cookie flags

- Remove all default accounts and passwords before deployment

Key takeaway

Strong identity checks and well-managed sessions are the foundation of application security.